

Company Case Study: Luigi's

A Luigi's Inc. employee brought a personal laptop into the facility infected (albeit unknowingly) with PSL and connected it to the corporate network via a wireless access point (AP). The system obtained an IP Address using Dynamic Host Configuration Protocol (DHCP) addressing provided by the core corporate network services. Upon connection, the infected system made an Internet connection to the command and control server.

Once connected, the threat actor provided the command for the system to scan the local network for available services. While the user noticed that the machine was running slowly, it was late on Friday before a three-day weekend. The user left the machine powered on with plans to look at it again on Tuesday. The scan identified an open File Transfer Protocol (FTP) service on the internal network that allowed anonymous access. The threat actor, still using the compromised machine, logged into the FTP server, compressed the contents and then transferred the data to the control server (over the internet) using an encrypted outbound VPN connection.

Over the weekend, the Network Operations Center (NOC) tracked a large amount of data over an encrypted channel. While they were able to identify both the source and destination, without the encryption keys, they were unable to decrypt the traffic to identify the content. The destination was not on the current list of known malicious sites (the list was out of date by four months). The help desk technician then opened a work ticket for the local desktop services to investigate.

Early Tuesday morning the user noticed that the machine was still acting erratically, even after a reboot. The user then called the help desk to open a ticket. The help desk technician was able to tie IP address of this machine to the traffic identified over the weekend. When the desktop technician arrived, it was determined that the machine in question is not a corporate machine and does not have all the standard protection software. A quick scan using a boot time tool found the PSL signature. At this point, the technician confiscated the machine for forensic investigation and the ticket was closed.

The forensics team determined a known malware tool named PSL compromised the machine. They also found a temporary file, left over by the scanning, that included the directory listing of the FTP site. Many of the folders within the directory were named after previous high-value programs. These files included parts lists, price quotes and even proprietary drawings. Included in the information, were patents from the current Chief Executive Officer (Ms. J. Rabbit) as well as legal documents describing the purchasing and legal aspects of these programs.